2. Kali Linux – Information Gathering Tools

In this chapter, we will discuss the information gathering tools of Kali Linux.

NMAP and ZenMAP

NMAP and ZenMAP are useful tools for the scanning phase of Ethical Hacking in Kali Linux. NMAP and ZenMAP are practically the same tool, however NMAP uses command line while ZenMAP has a GUI.

NMAP is a free utility tool for network discovery and security auditing. Many systems and network administrators also find it useful for tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime.

NMAP uses raw IP packets in novel ways to determine which hosts are available on the network, what services (application name and version) those hosts are offering, which operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, etc.

Now, let's go step by step and learn how to use NMAP and ZenMAP.

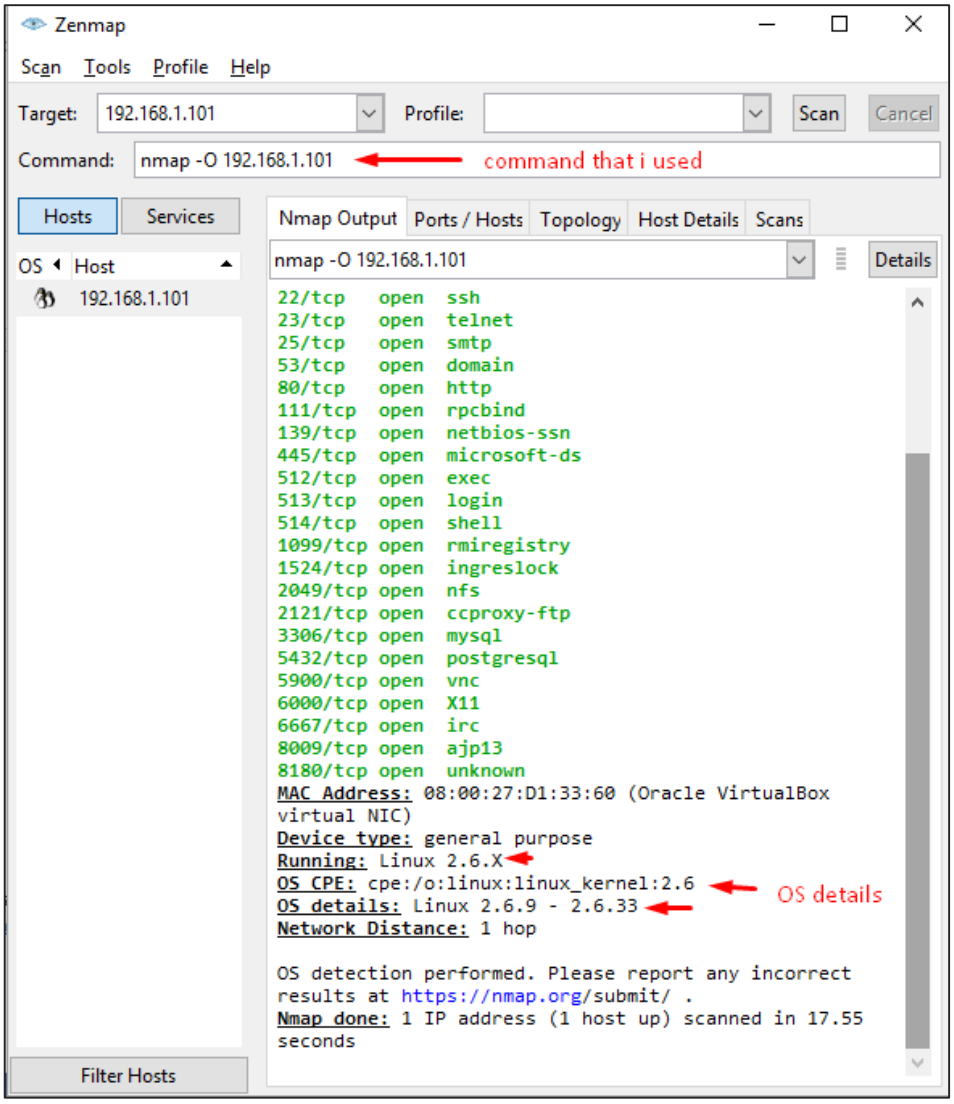
Step 1: To open, go to Applications -> 01-Information Gathering -> nmap or zenmap.

Step 2: The next step is to detect the OS type/version of the target host. Based on the help indicated by NMAP, the parameter of OS type/version detection is variable "-O". For more information, use this link: https://nmap.org/book/man-os-detection.html

The command that we will use is:

```
nmap -O 192.168.1.101
```

The following screenshot shows where you need to type the above command to see the Nmap output:

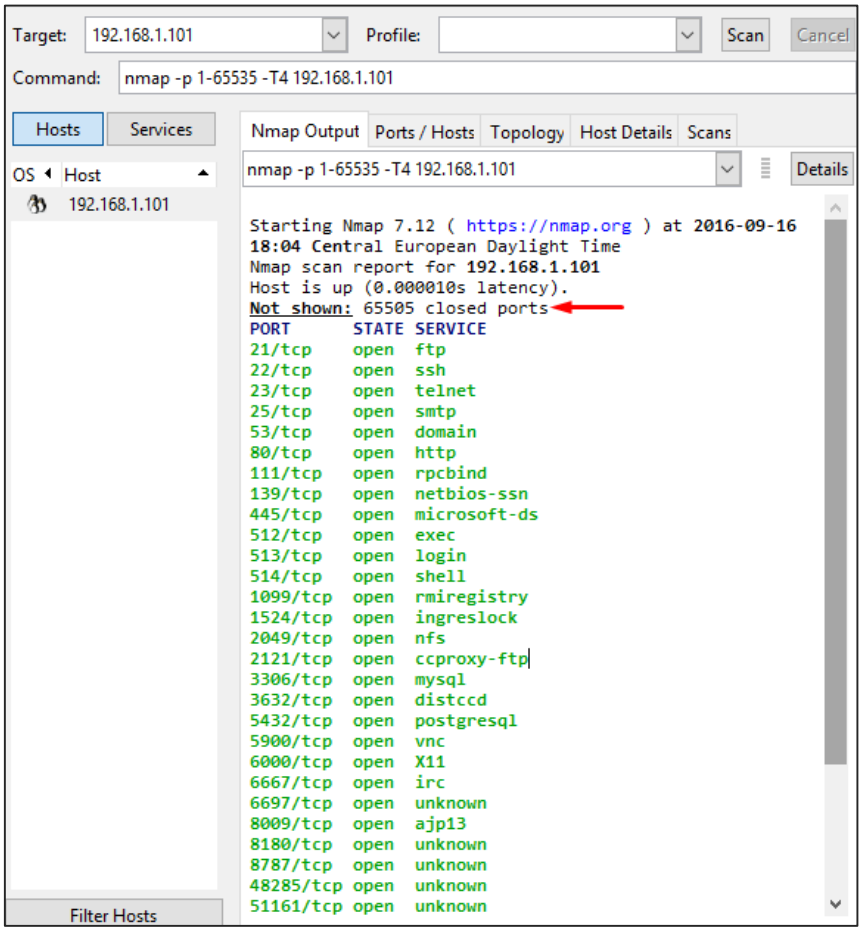


Step 3: Next, open the TCP and UDP ports. To scan all the TCP ports based on NMAP, use the following command:

```
nmap -p 1-65535 -T4  192.168.1.101
```

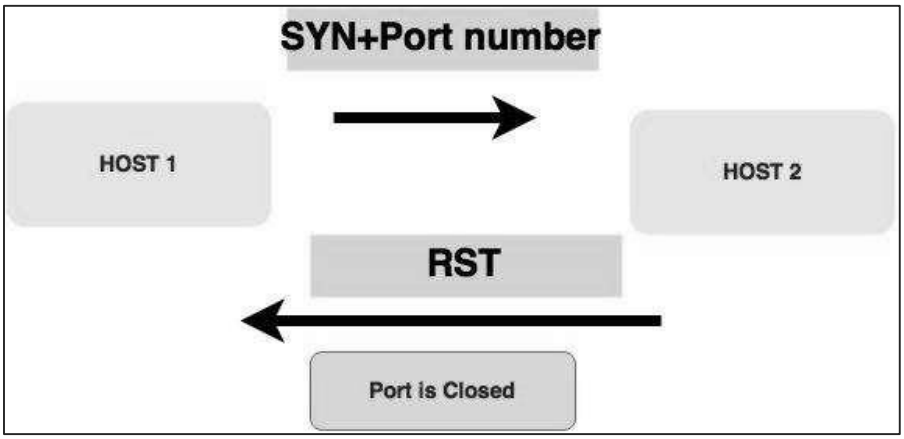
Where the parameter "–p" indicates all the TCP ports that have to be scanned. In this case, we are scanning all the ports and "-T4" is the speed of scanning at which NMAP has to run.

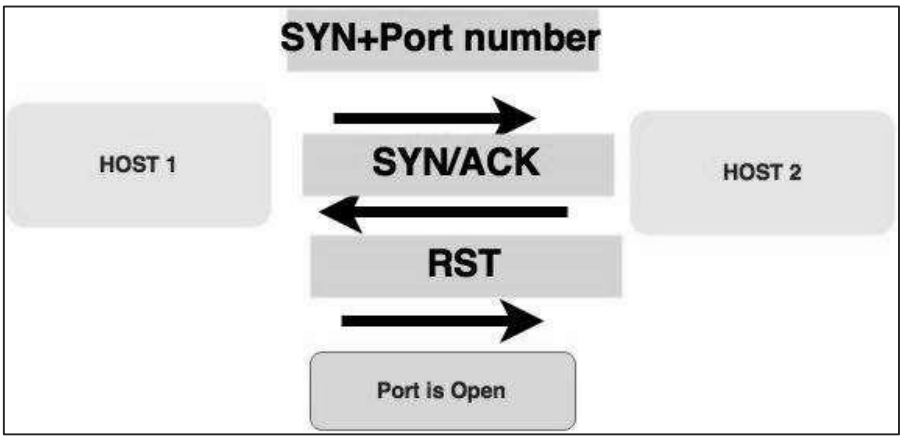
Following are the results. In green are all the TCP open ports and in red are all the closed ports. However, NMAP does not show as the list is too long.



Stealth Scan

Stealth scan or SYN is also known as **half-open scan**, as it doesn't complete the TCP three-way handshake. A hacker sends a SYN packet to the target; if a SYN/ACK frame is received back, then it's assumed the target would complete the connect and the port is listening. If an RST is received back from the target, then it is assumed the port isn't active or is closed.

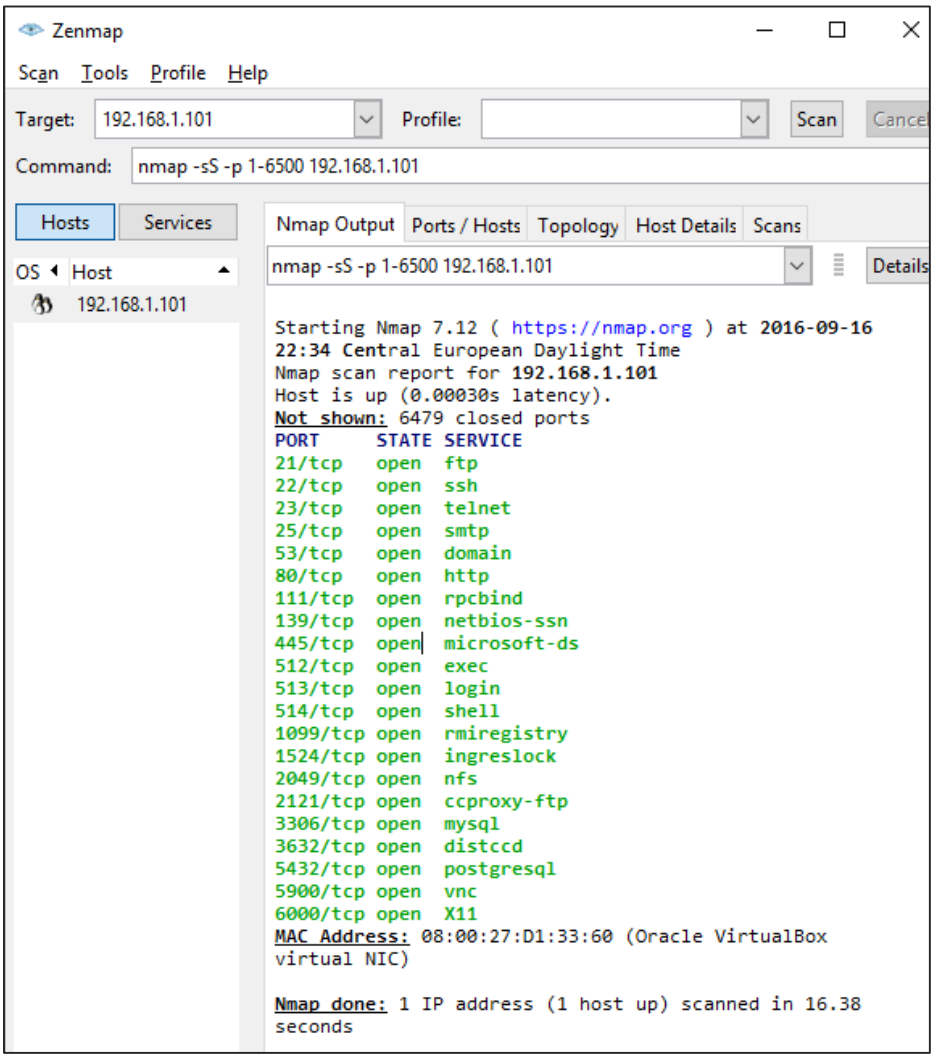




Now to see the SYN scan in practice, use the parameter **–sS** in NMAP. Following is the full command –

```
nmap -sS -T4 192.168.1.101
```

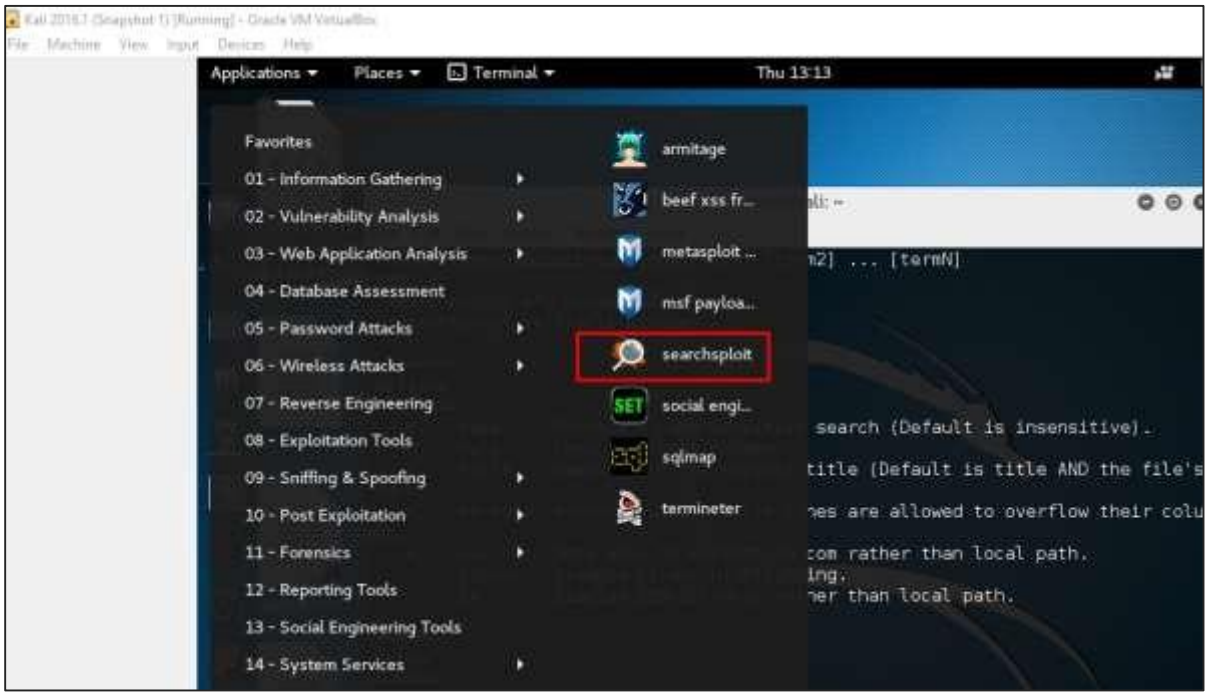
The following screenshot shows how to use this command:



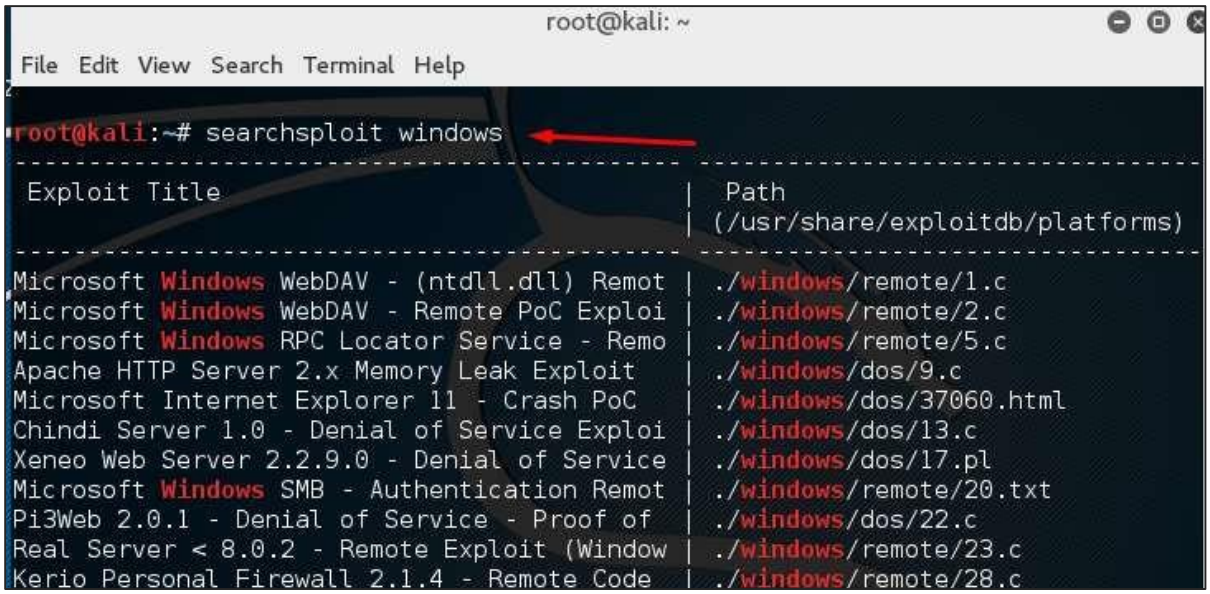
Searchsploit

Searchsploit is a tool that helps Kali Linux users to directly search with the command line from Exploit database archive.

To open it, go to Applications -> 08-Exploitation Tools -> searchsploit, as shown in the following screenshot.



After opening the terminal, type "**searchsploit *exploit index name***".



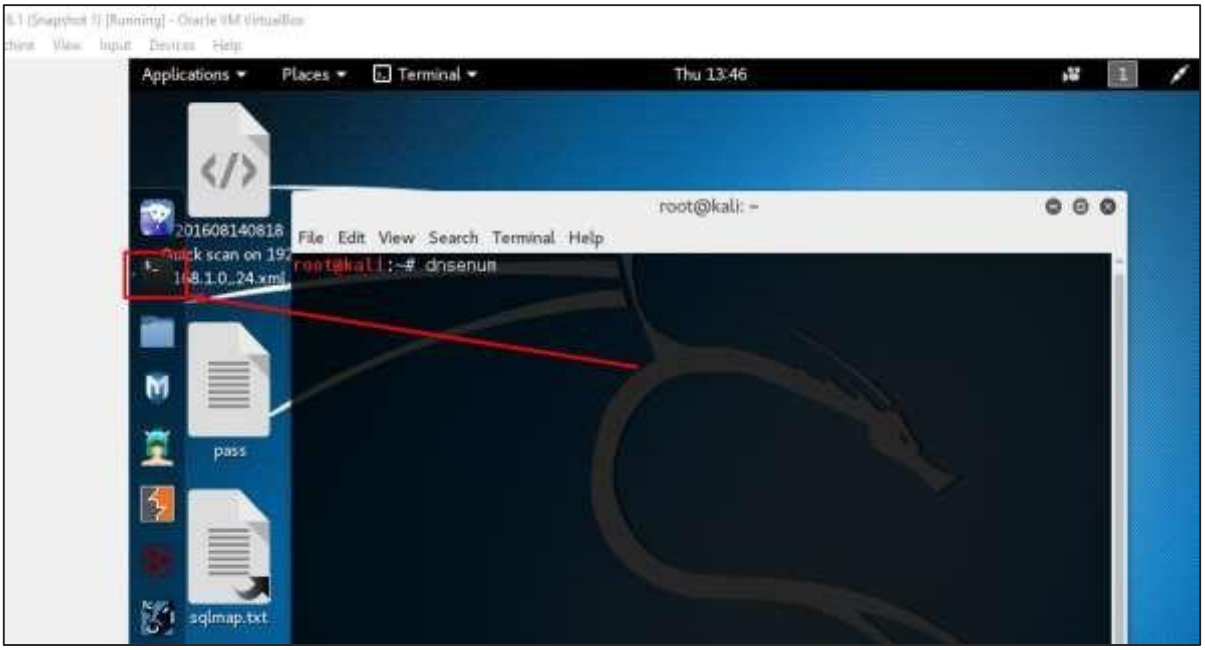
DNS Tools

In this section, we will learn how to use some DNS tools that Kali has incorporated. Basically, these tools help in zone transfers or domain IP resolving issues.

dnsenum.pl

The first tool is **dnsenum.pl** which is a PERL script that helps to get MX, A, and other records connect to a domain.

Click the terminal on the left panel.



Type "**dnsenum domain name**" and all the records will be shown. In this case, it shows A records.

```
brute force file not specified, bay.
root@kali:~# dnsenum [redacted]e.com[redacted]
dnsenum.pl VERSION:1.2.3
----- example.com -----

Host's addresses:
__________________

[redacted].com.                          81654    IN    A        [redacted]6.34

Name Servers:
_____________

a.iana-servers.net.                      293      IN    A        [redacted].53
b.iana-servers.net.                      1717     IN    A        [redacted]53

Mail (MX) Servers:
__________________

Trying Zone Transfers and getting Bind Versions:
________________________________________________

Trying Zone Transfer for example.com on a.iana-servers.net ...
AXFR record query failed: RCODE from server: NOTAUTH
```

DNSMAP

The second tool is **DNSMAP** which helps to find the phone numbers, contacts, and other subdomain connected to this domain, that we are searching. Following is an example.

Click the terminal as in the upper section , then write "**dnsmap *domain name***"

```
root@kali:~# dnsmap [redacted].al
dnsmap 0.30 - DNS Network Mapper by pagvac (gnucitizen.org)

[+] searching (sub)domains for [redacted].al using built-in wordlist
[+] using maximum random delay of 10 millisecond(s) between requests

cpanel.[redacted].al
IP address #1: [redacted].222

ftp.[redacted].al
IP address #1: [redacted].222

localhost.[redacted].al
IP address #1: 127.0.0.1
[+] warning: domain might be vulnerable to "same site" scripting (http://snipurl.com/etbcv)

[+] 3 (sub)domains and 3 IP address(es) found
[+] completion time: 150 second(s)
```

dnstracer

The third tool is **dnstracer**, which determines where a given Domain Name Server (DNS) gets its information from for a given hostname.

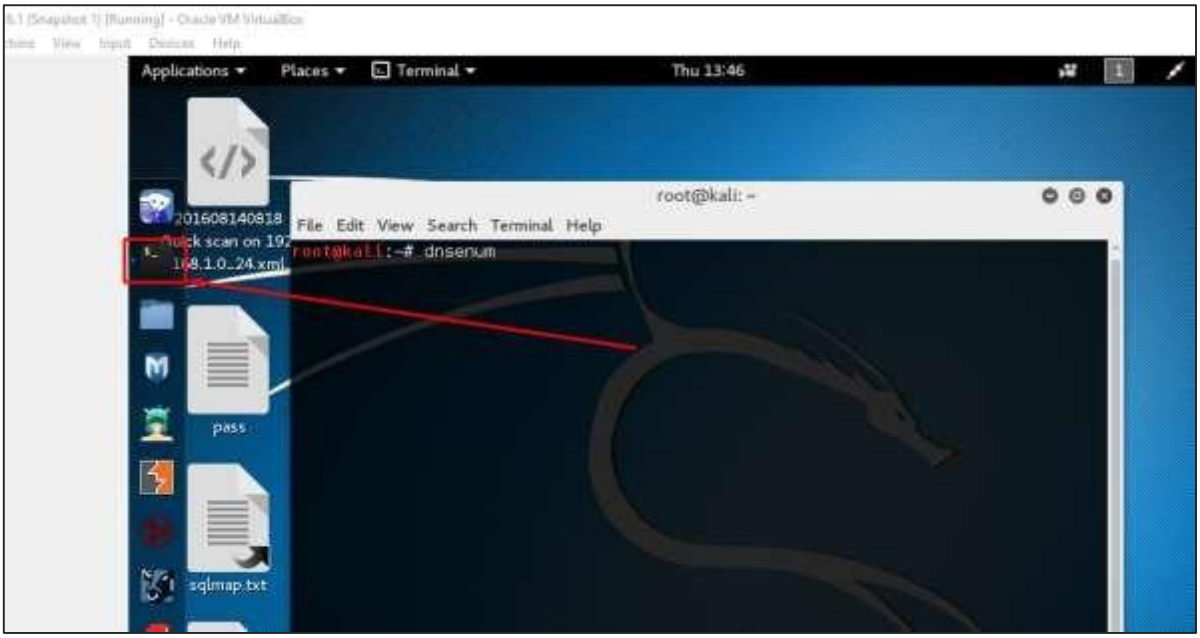
Click the terminal as in the upper section, then type "**dnstracer *domain name***".

```
root@kali:~# dnstracer [redacted].com
Tracing to [redacted].com[a] via 127.0.0.1, maximum of 3 retries
127.0.0.1 (127.0.0.1) * * *
```

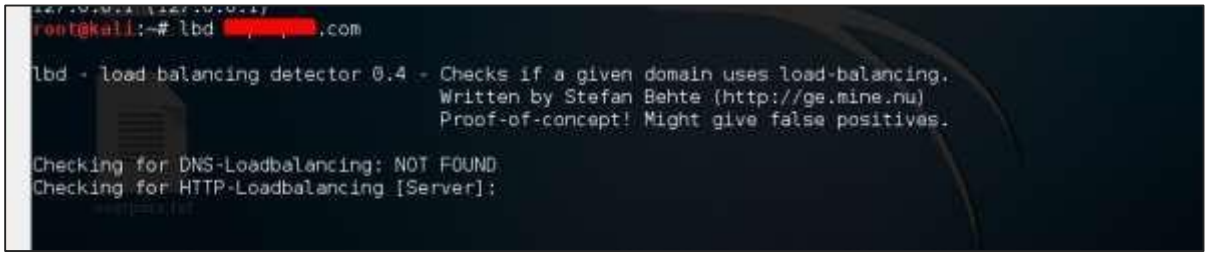
LBDTools

LBD (Load Balancing Detector) tools are very interesting as they detect if a given domain uses DNS and/or HTTP load balancing. It is important because if you have two servers, one or the other may not be updated and you can try to exploit it. Following are the steps to use it:

First, click the terminal on the left panel.



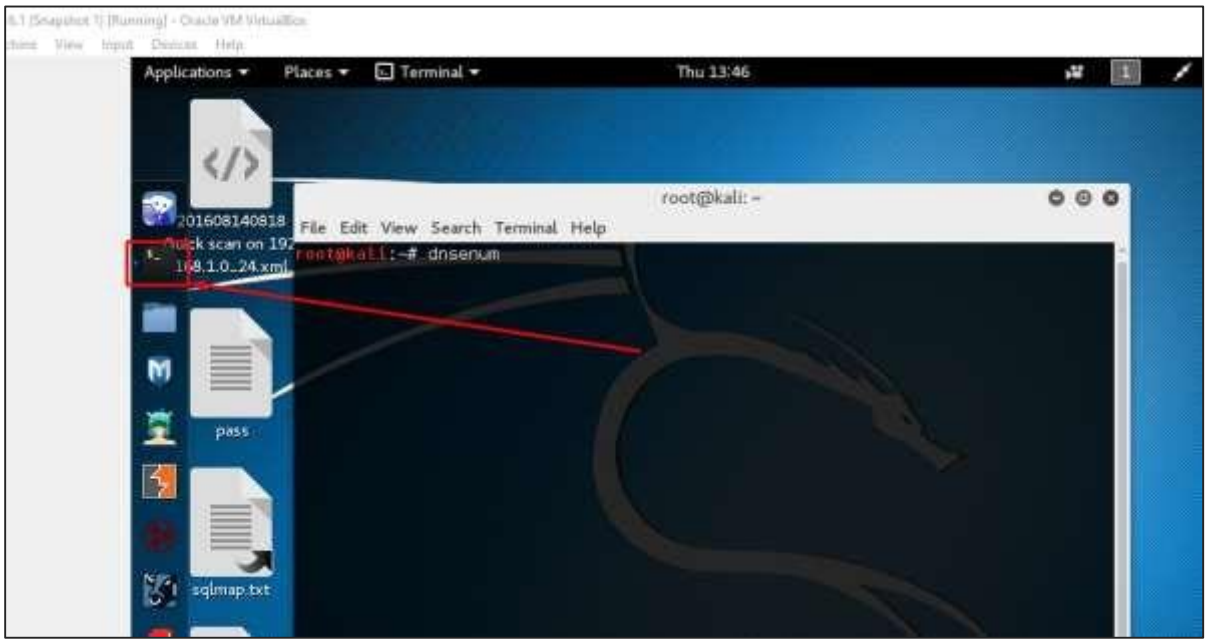
Then, type "**lbd *domainname"***. If it produces a result as "FOUND", it means that the server has a load balance. In this case, the result is "NOT FOUND".



Hping3

Hping3 is widely used by ethical hackers. It is nearly similar to ping tools but is more advanced, as it can bypass the firewall filter and use TCP, UDP, ICMP and RAW-IP protocols. It has a traceroute mode and the ability to send files between a covered channel.

Click the terminal on the left panel.



Type **"hping3 –h"** which will show how to use this command.

```
root@kali:~# hping3 -h
usage: hping3 host [options]
  -h  --help      show this help
  -v  --version   show version
  -c  --count     packet count
  -i  --interval  wait (uX for X microseconds, for example -i u1000)
      --fast      alias for -i u10000 (10 packets for second)
      --faster    alias for -i u1000 (100 packets for second)
      --flood      sent packets as fast as possible. Don't show replies.
  -n  --numeric   numeric output
  -q  --quiet     quiet
  -I  --interface interface name (otherwise default routing interface)
  -V  --verbose   verbose mode
  -D  --debug     debugging info
  -z  --bind      bind ctrl+z to ttl           (default to dst port)
  -Z  --unbind    unbind ctrl+z
      --beep      beep for every matching packet received
Mode
  default mode     TCP
  -0  --rawip      RAW IP mode
  -1  --icmp       ICMP mode
  -2  --udp        UDP mode
```

The other command is **"hping3 domain or IP -parameter"**

```
root@kali:~# hping3 192.168.1.102 -V
using eth0, addr: 192.168.1.101, MTU: 1500
HPING 192.168.1.102 (eth0 192.168.1.102): NO FLAGS are set, 40 headers + 0 data
bytes
len=46 ip=192.168.1.102 ttl=64 DF id=0 tos=0 iplen=40
sport=0 flags=RA seq=0 win=0 rtt=10.6 ms
seq=0 ack=982034245 sum=c40 urp=0

len=46 ip=192.168.1.102 ttl=64 DF id=0 tos=0 iplen=40
sport=0 flags=RA seq=1 win=0 rtt=0.4 ms
seq=0 ack=1964174310 sum=dfc0 urp=0
```

```
:~# metagoofil -d [redacted].com -t pdf -l 20 -n 10 -o /root/Desktop/working
/ -f [redacted].html

*********************************************************
*     /\/\   ___| |_ __ _  __ _  ___   ___  / _(_) | *
*    /    \ / _ \ __/ _` |/ _` |/ _ \ / _ \| |_| | | *
*   / /\/\ \  __/ || (_| | (_| | (_) | (_) |  _| | | *
*   \/    \/\___|\__\__,_|\__, |\___/ \___/|_| |_|_| *
*                            |___/                    *
* Metagoofil Ver 2.2                                 *
* Christian Martorella                               *
* Edge-Security.com                                  *
* cmartorella_at_edge-security.com                   *
*********************************************************
['pdf']

[-] Starting online search...

[-] Searching for pdf files, with a limit of 20
```